

DIGITAL FORENSICS & BIOMETRICS

A.A. 2026/2027

DISK AND MOBILE FORENSICS

Simone Milani
Room 216
DEI A

Phone: 049 827 7641
E-mail:
simone.milani@dei.unipd.it

SOME TIPS

- Use proper forensic tools to document and analyze data
- Maintain access logs
- Timestamp operations
- Verify and hash data
- All the team must be trained and aligned to specific protocols

ADDITIONAL NOTES ON CHAIN OF CUSTODY

- Document and justify every possible alteration (with the name of the person which is responsible for that)
- Record dates if items are released to anyone
- Restrict access to the evidence
- Place original hard drive to a locker
- Perform all forensics on a mirror copy

LOOKING FOR TRACES ON DATA DEVICES

MEMORY DEVICE ACQUISITION QUESTIONS

- How many computers/HD to acquire?,
- What type of computer (e.g., desktop, laptop, server)?
- What are the sizes of the storage for each computer?
- Storage device issues (SSD, Encryption, …)?

DATA STORED ON A DIGITAL DEVICES

Problem: retrieve relevant information from a memory device

- Number of possible files and application is very large
- Look only for what is relevant to the specific case (but this could require an exhaustive analysis, anyway)
- Disk and operating system investigation tools exist in the commercial, free and open source domains.
- Operations must be accurately chosen depending on the device and the data to be retrieved

What to look for? Many traces can be found

How to look for?

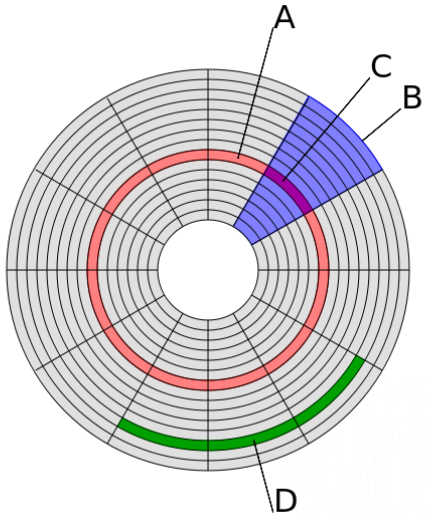
MEMORY SPACE ON A DEVICE

In computer file systems, a **cluster** or **allocation unit** is a unit of disk space allocation for files and directories.

To optimize disk management, filesystems do not allocate individual sectors but contiguous groups of sectors (clusters).

Allocated: used to store data, metadata, programs

Non-allocated: available



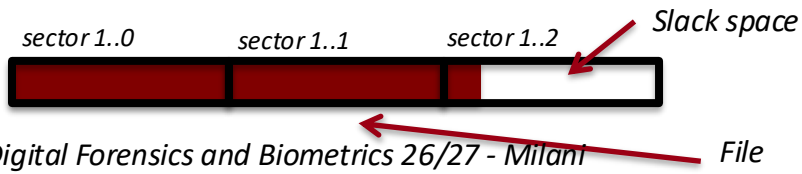
A: track
B: geometrical sector
C: track sector
D: cluster

Image courtesy from Wikipedia

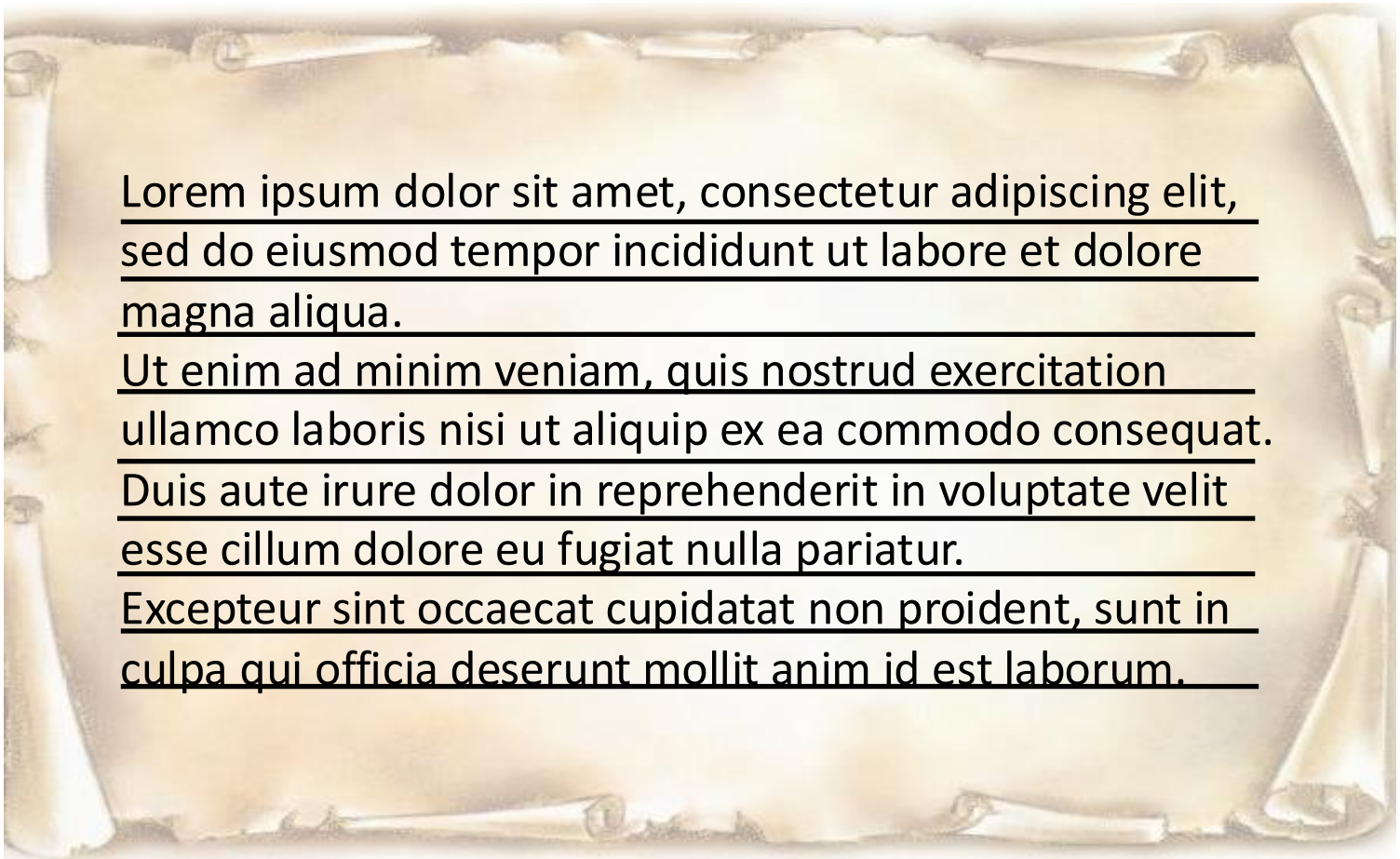
Slack space: area between the last bit of a file and the end of the last assigned sector (wasted).
Sometimes the term is extended referring to any part of a memory which is not indexed any more.

Every sector can be assigned to a single file; a single file can be stored in multiple sectors.

Example: NTFS
Clusters: 4Kb File: 9 Kb = 3 clusters for a total of 12 Kb
3 Kb of slack space!



EXAMPLE ON A SHEET

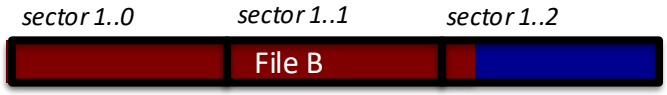


TRACES FROM DISK SPACES

Files are indexed by the filesystem (one or more per file). Removing the file implies deleting the indexes: data are still present on device until they are overwritten by another file. Infos are there.

Example 2: NTFS

Clusters: 4Kb File A: 12 Kb = 3 clusters for a total of 12 Kb
No slack space.



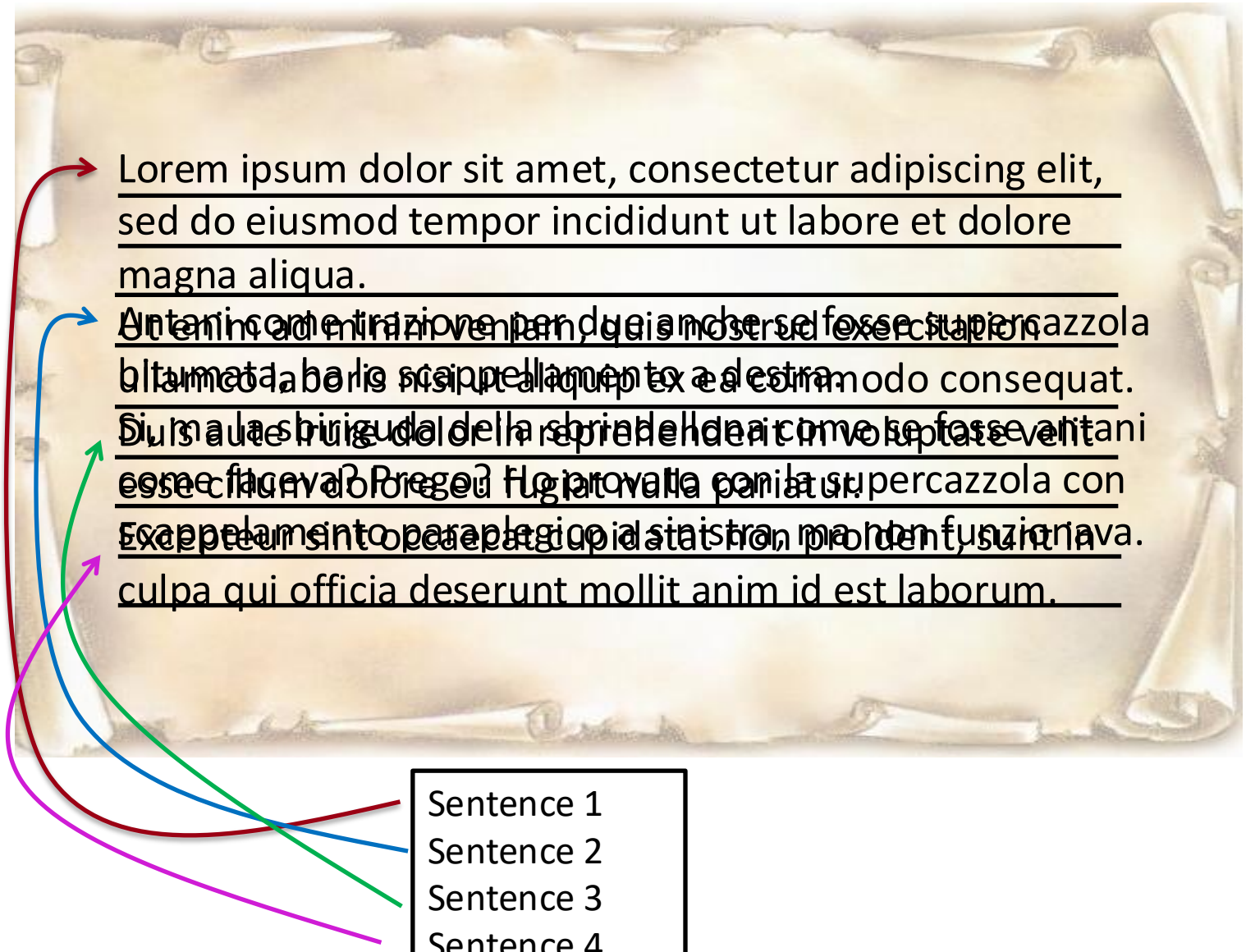
Remove File A and write File B: part of the data are still present!

Note that before a space is overwritten, it would require a long time.

Some data can be retrieved from the so-called **G-list:** damaged sector that can not be used any more but that can be read!

45 % of data that can be read from a hard disk are in slack and non-index spaces!

EXAMPLE ON A SHEET



SOLID STATE DRIVE

- SD store data on flash memory chips.
- No delays due to spinning disk (simultneous access)
- File recovery is much more challenging!

Basic problem in SSD: blocks need to be erased before being written.



TRIM (TRIM in ATA set or UNMAP in SCSI)

- issued by OS to SSD controller at file deletion, disk formatting, or partition removal
- Says which block of data are no longer used



Garbage Collection

- cleans or purges the data blocks marked as deleted.
- Implemented on disk itself (not controlled by OS): if PC is shut dow, it restarts when powered on or even if attached to a write blocker

Encryption and Compression

Result: purging of data block is unavoidable!

DO NOT DESPAIR …

Data blocks and file carving is still possible anyway

TRIM limitations:

- TRIM is not supported
- PC support RAID environment, external SSD and NAS.
- SSD connected through USB (TRIM is only supported in SATA, eSATA, and SCSI)
- buggy firmware in the SSD.
- the file is just corrupted and not deleted.

Example: SATA protocol, different protocols after TRIM command

1.Non-deterministic TRIM: each read command may return different data

2. Deterministic Read After TRIM (DRAT): all read commands shall return the same data,

3. Deterministic Zero After TRIM (DZAT): all read commands shall return zeroes until the page is written with new data.

G. Ninahualpa, S. Yoo, T. Guarda, J. Díaz and D. Piccirilli, "Protocol of Information Recovery in Solid Hard Drives - SSD Using File Carving Techniques," 2019 14th Iberian Conference on Information Systems and Technologies (CISTI), Coimbra, Portugal, 2019, pp. 1-6, doi: 10.23919/CISTI.2019.8760783

Zubair Shah, Abdun Naser Mahmood, Jill Slay: Forensic Potentials of Solid State Drives. SecureComm (2) 2014: 113-126

WHAT TO DO ?

- Attach SSD to a secondary channel of the motherboard (not primary drive)
- Check if disk is close to full
- Check the garbage collector characteristics (vendor related issue)



FILESYSTEMS

Filesystems handle data in a different way: we need different strategies!

Data are fragmented into multiple (and sometimes not contiguous) sectors: indexing information permits retrieving all the parts.

Removal:

- Erase the address of the table that contains the indexes of all the parts of the file
- Files are moved to another directory (trashbin)

Data are still there unless
-overwritten
-removed with wiping software

Links:
https://compute-forensics.com/top-ten-free-computer-forensic-software/

https://compute-forensics.com/top-ten-free-computer-forensic-software/

http://resources.infosecinstitute.com/computer-forensics-tools/#gref

https://techtalk.gfi.com/top-20-free-digital-forensic-investigation-tools-for-sysadmins/

DATA CARVING

Files can have different extensions

Magic number is a constant that identifies the file type

PDF: starts with %PDF and ends with %EOF
JPG: starts with 0xFFD8 and ends with 0xFFD9

(use `hexedit` *or* `hexdump` *to view;* `file` *on Linux)*

- **Data carving** is a process of extracting a set of data/information from a wider set of data
- In forensic analysis data carving is used to find data in the non-allocated space
- File classified from headers and footers
- Structure of filesystem is ignored.



WHAT DATA CARVING ALLOWS …

Base conditions:

- Header and footer have not been overwritten
- The file is not fragmented
- The file is not compressed
- The file is included between header and footer

Advanced conditions:

- Non-sequential fragments
- Non-ordered fragments
- Some fragments are missing



- ❑ Recovering deleted or fragmented files (fragments) from damaged memories; it can be used on RAM dumps as well.
- ❑ Performed on device or image
- ❑ Footer can be missing
- ❑ Beware of false positives!

Tools: `foremost, scalpel, photorec` (they work on blocks)

FOREMOST

Does not consider file system.

Creates output file `audit.txt` and a set of subfolders for each file type

- *Based on headers and footers*
- *File active, erased, not-allocated*

Recover data from formatted disks/memories

Names are not recovered (name=sector address)

Audit collect file names and offsets

Example: recover data from USB pen /dev/sda1 in USB /dev/sdb

```
$sudo mount /dev/sdb1 /data_recovery -o rw
$sudo foremost -i /dev/sda1 -o /data-recovery

#Look for all files on image.dd
$sudo foremost -t all -i image.dd
#Look for jpg and gif files
$sudo foremost -t jpg,gif -i /dev/sda1 -o /data-recovery
#Look for office documents
$sudo foremost -t ole,jpeg -i image.dd
#Skip the first 10000 blocks
$sudo foremost -s 10000 -t ole,jpeg -i image.dd
```

FOREMOST: AUDIT.TXT FILE

```
Foremost version 1.5.7 by Jesse Kornblum, Kris Kendall,
and Nick MikusAudit
FileForemost started at Fri Apr 20 10:15:45 2011
Invocation: foremost /dev/sda1
Output directory: /data-recovery
Configuration file: /usr/local/etc/foremost.conf
------------------------------------------------
File: /dev/sda1
Start: Fri Apr 20 10:15:45 2011
Length: 962 MB (1009254400 bytes)
Num Name (bs=512)
Size File Offset Comment0:
0: 00000621.jpg 11 KB 312832
1: 00000743.jpg 8 KB 329216
2: 00000774.jpg 3 KB 345600
3: 00000877.jpg 9 KB 361984
4: 00000983.jpg 8 KB 378768
```

Byte size of sector is 512

It was on sector 611

Offset is 512*621=312832
(byte address of file on disk)

Verify sector on disk

```
$ xxd -s 312832 -l 512 /dev/sda1

004c600: ffd8 ffe0 0010 4a46 4946 0001 0100 0001 ......JFIF......
004c610: 0001 0000 ffdb 0043 0005 0304 0404 0305 .......C........
004c620: 0404 0405 0505 0607 0c08 0707 0707 0f0b ................
004c630: 0b09 0c11 0f12 1211 0f11 1113 161c 1713 ................
004c640: 141a 1511 1118 2118 1a1d 1d1f 1f1f 1317 ......!.........
004c650: 2224 221e 241c 1e1f 1eff db00 4301 0505 "$".$.......C...
004c660: 0507 0607 0e08 080e 1e14 1114 1e1e 1e1e ................
```

PHOTOREC

Recovery tool for many types of files

Can be used together with TestDisk

Open source

Recognize 400 different formats (ZIP, Office, PDF, HTML, JPG, etc…)

AUTOPSY + SLEUTH KIT

Sleuth Kit is a suite of tools for disk and file system forensics

Autopsy Forensic Browser is its interface

- Permits analyzing, disks, images,
- Generate a timeline
- Generate hashes
- Permits looking for file types
- Permits looking for a specific content in files
- Looks for erased files

DISK ENCRYPTION

- HW encryption
- SW encryption
- Hybrid encryption



SW encryption is:
- run by an application
- slower
- tied to a set of keys but not bound to a specific machine or platform
- E.g. TrueCrypt

As for HW encryption
- operated at firmware level; relies on Trusted Machine Platform (TPM) chip
- entire drive (incl. boot sector, OS, temporary files, and swap files) are encrypted
- Faster, managed by the control system of the HD

Hybrid instead
- is software but can be linked to a specific HD
- relies n TPM as well
- access can be in transparent operating mode, user authenticated or USB authenticated
- eg. Windows BitLocker

How to circumvent?



SW encryption

- Cold reboot attack (exploits DRAM not completely erased - boot a malicious operating system that copies the contents of memory)
- Pieces of files can be found outside the encrypted area (temporary storage) - Correct and incorrect password – it depends how encryption is married with OS

HW encryption

- Pieces of files can be found outside the encrypted area
- Avoid sleeps or shutting down: when re-enacted password must be entered
- Some systems aim at creating recovery keys: stored in clear view, they can be used to decrypt the disk
- Exploits TPM weaknesses: keys can be stored in clear



Anyway, encryption can be extremely useful in destroying evidences: reset/wipe encryption keys

Mobile forensics

MOBILE DEVICES

Recovering traces from mobile devices involve more than simply files!

Traces: IMEI, SIM cards, images, …

Steps:

- Identification and evidence collection
- Acquisition and verification
- Conservation
- Valutation and presentation

IDs FOR MOBILE DEVICES (1/2)

IMEI codes: every mobile terminals is identified by a 15 characters code (International Mobile Equipment Identifier or IMEI), used to identify the device within the mobile network

- Vendor
- Model
- Nation

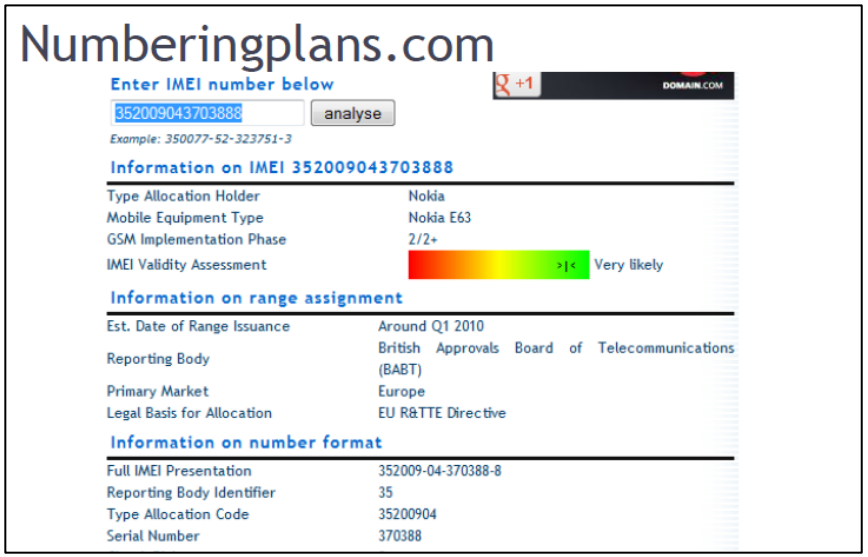


How to get it?

Switched off devices: look on the back or under the battery
Switched on devices: dial ***#06#**

Post the number on

http://www.numberingplans.com/
http://www.trackimei.com/

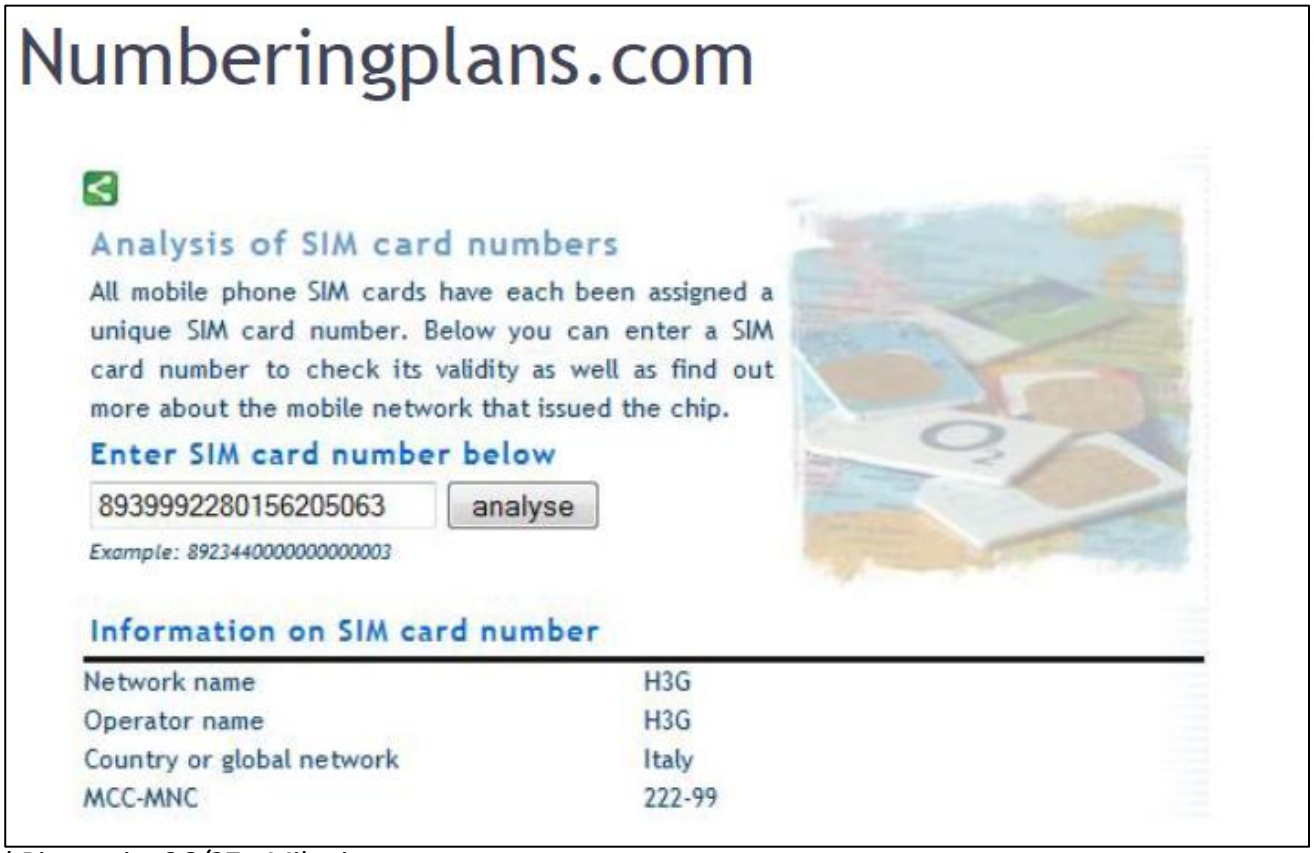


IDs FOR MOBILE DEVICES (1/2)

Subscriber Identity Module (SIM) card: required to access a mobile network.

Every SIM card is characterized by a **Integrated Circuit Card Identification (ICCID)** number.

http://www.numberingplans.com/ allows to get information about the network given the ICCID code.



COLLECTION/SEIZURE OF MOBILE DEVICES (1/2)

① Secure the phone/tablet

② Isolate it and prevent other people from operating with it

③ Notate eventual physical defects (e.g., broken display, etc.)

④ Take pictures of the device

⑤ Document all the actions

⑥ Verify if switched on or off

⑦ If the device is off, leave it switched off.

COLLECTION/SEIZURE OF MOBILE DEVICES (2/2)

In case the phone is on,

- ❑ Document the information on the screen
- ❑ If possible, register date and time of the device verifying the eventual offset with respect to the real time.
- ❑ Avoid navigating the menu or opening messages
- ❑ Keep it switch on isolating it from the possible network connections
  - Bluetooth 2,45GHz
  - Wi-Fi
  - GSM/UMTS/LTE
  - GPS1575MHze1227MHz

Isolation can be done with

- Jammer



- Faraday's cage



- Airplane mode
  (verify all connections are off)

or

- ❑ Switch it off with normal shutdown or removing the battery

SWITCHING OFF VS. ISOLATION

Switching the device off could enable phone lock and require an unlocking code (e.g., PIN of SIM card or lock number of the phone)

Using jammers or Faraday's cages imply a waste of battery (the phone keeps on trying to connect) ➡ need for external power charge to keep it on.

Airplane mode isolates the phone without risks … anyway, if you do not know the model you still can mess up the things ….